Элементы безопасности в Учебной Госпитальной информационной системе

Лабораторная 2 основана на Лабораторной 1 и является ее продолжением. В Учебную HIS добавляются минимальные элементы обеспечения информационной безопасности.

Новые и измененные сущности

1. Аккаунт пользователя
   - id - uuid
   - username - текст от 3 до 16 символов, уникальное
   - passwordHash - текст
   - createdAt - timestamp
   - updatedAt - timestamp
   - isActive - bool
2. Запись аудита
   - eventId - uuid
   - eventTime - timestamp
   - actor - идентификатор, по которому однозначно понятно кем или чем инициировано событие, подумайте, как правильно реализовать это требование
   - message - текст - описание того, что произошло
3. Медработник
   - Минимальную длину полей для имен и фамилий сделать один символ
   - Добавить поле role - enum {doctor|laboratory-technician|nurse|other}

Хранение паролей

Пароли хранятся в виде хэшей с использованием KDF. Допустимые варианты: Argon2, Bcrypt, Scrypt.

Защита трафика между сервером и клиентом

Передача данных между сервером API и клиентом должна быть защищена протоколом TLS версии 1.3. Создать собственный корневой сертификат CA и подписать им серверный сертификат, в которых у Издателя наименование организации "ITMO", наименование подразделения "MedSoft 2026/27 NNN", где NNN - ваш ИСУ ID. Допускается ручная установка доверия к учебному корневому сертификату. Отключение проверки сертификата в клиентском приложении не допускается. Разберитесь с Issuer и Subject.

Сервер авторизует запросы при помощи JWT токенов с асимметричной схемой подписи. Должен быть реализован механизм access и refresh токенов. Токены должны иметь ограниченный срок действия, меняются парой.

Изменения в интерфейсах

В интерфейс администратора добавляется раздел "Аудит". Это список записей аудита в хронологическом порядке. Список обновляется в реальном времени с задержкой не более двух секунд. События, которые должны фиксироваться в аудите:

1. Логин админа
2. Логин пользователя
3. Неуспешные попытки логина
4. Добавление, изменение, удаление медработника
5. Добавление, изменение, удаление пациента
6. Добавление, изменение ЭМК
7. Изменение аккаунта
   Средствами приложения изменять записи аудита нельзя.

В интерфейс администратора добавляется раздел "Аккаунты". Это список аккаунтов с соответствующими полями.

В интерфейсе администратора в разделе управления медработниками добавляется функция создания аккаунта пользователя для медработника. Аккаунт пользователя можно создать, сгенерировать новый пароль (12 символов, допустимы большие и маленькие буквы латинского алфавита, цифры), активировать/деактивировать. Для медработника можно изменить его роль (other по умолчанию). Каждый аккаунт пользователя связан с не более чем одним медработником. У медработника может быть не более одного аккаунта. Аккаунты пользователя могут существовать самостоятельно, но штатными средствами этого сделать нельзя.

В интерфейсе медработника создание пациентов и ЭМК допускается только для медработника с ролью doctor или nurse, а разблокировка ЭМК для редактирования только для медработника с ролью doctor. Ручной выбор действующего лица удалить. Просматривать ЭМК может медработник с любой ролью.

Сценарии

1. При первом входе в интерфейс админа, когда пароль и двухфакторная аутентификация не настроены, производится задание пароля администратора с проверкой и настройка двухфакторной аутентификация по протоколу TOTP RFC 6238. При первоначальной настройке TOTP система предоставляет секрет в виде QR-кода или строки для ручного ввода. Настройка завершается только после успешной проверки одноразового кода. После настройки логин в систему для админа осуществляется только через ввод пароля и актуального кода TOTP.

Аккаунт админа один для всей системы. Механизм восстановления доступа для двухфакторной аутентификации не требуется.

2. В интерфейс медработника можно попасть только после авторизации аккаунта пользователя с данными, полученными у админа. Аккаунт должен быть активен. Для авторизации достаточно логина и пароля.
3. При деактивации аккаунта пользователя, смене пароля или смене роли связанного с аккаунтом медработника refresh токены этого аккаунта отзываются с указанием их количества в аудите.

Важно

Ограничения доступа должны обеспечиваться сервером API независимо от пользовательского интерфейса. Проверка права на выполнение операции проводится при каждом запросе на основе информации из access токена.

Необходимо обеспечить фиксацию событий в аудите, инициированных как аутентифицированными, так и неаутентифицированными субъектами.

При логическом удалении медработника связанный аккаунт автоматически деактивируется.

Доступ к WebSocket-соединениям, если они есть, должен контролироваться теми же правилами авторизации, что и доступ к соответствующим данным через API.

В результате выполнения лабораторной работы в систему из Лабораторной 1 должны быть добавлены элементы, обеспечивающие базовую безопасность. Пользовательские интерфейсы для медработников и администраторов должны быть разделены.